



**FATEC – FACULDADE DE TECNOLOGIA DE SÃO CAETANO DO SUL
ANTÔNIO RUSSO**

Proposta de Arquitetura de Cibersegurança em Camadas Baseada no Framework NIST

Efraim de Almeida Lima

**Abril – 2026
SÃO CAETANO - SP**

ÍNDICE

1. Introdução
2. Camada de Borda e Mitigação Externa (Edge Security)
3. Controle de Fronteira e Filtragem de Rede (Block List & Network Protection)
4. Domínio de Dados e Virtualização (Data Domain)
5. Monitoramento de Servidores e Estações (Data Domain)
6. Monitorização, Detecção e Resposta (SIEM, EDR & XDR)
7. Conclusão

1. Introdução

A evolução das ameaças cibernéticas exige que as organizações abandonem modelos de segurança baseados apenas no perímetro físico. Esta arquitetura adota o conceito de **Defesa em Profundidade**, segmentando a infraestrutura em camadas lógicas que garantem redundância e granularidade no controle de acessos.

2. Camada de Borda e Mitigação Externa (Edge Security)

A primeira barreira de defesa atua antes que o tráfego atinja a infraestrutura local, focando na disponibilidade e integridade do tráfego de entrada.

CDN & Edge Protection: Implementação de Redes de Entrega de Conteúdo para distribuição de carga e ocultação do endereço IP real da origem.

- Ocultação de Origem: Impedir que o IP do roteador de borda seja exposto publicamente;
- Caching Estratégico: Reduzir a carga nos servidores internos servindo conteúdo estático na borda;
- Anycast Network: Distribuir o tráfego globalmente para mitigar latência e ataques volumétricos.

Mitigação de DDoS: Filtragem de tráfego em larga escala para garantir a disponibilidade, Este aqui estaria atrelado ao Firewall.

- Mitigação de Camada 3, 4 e 7: Bloqueio de ataques de inundação (SYN, UDP flood) e ataques de exaustão de recursos HTTP;
- Reputação de IP Global: Bloqueio automático de IPs conhecidos por botnets antes de atingirem a rede local.

NG Firewall: Implementar um NG Firewall para bloquear acessos dos usuários indevidos no ambiente

- Proteção de acesso
- Listas de ACL
- LDAP/RADIUS (Jogar pra autenticação local - Data Domain) -> consome recursos do roteador 802.1X
- IPS/IDS: Detecção e prevenção de intrusão baseada em assinaturas e anomalias;
- Control application

3. Controle de Fronteira e Filtragem de Rede (Block List & Network Protection)

Esta camada é responsável pela inspeção técnica e lógica dos pacotes que atravessam o perímetro da organização.

Roteador de Borda: Implementar um roteador de borda para filtrar pacotes maliciosos

- Inspeção de pacotes (SPI)
- Criptografia de comunicação (VPN + MFA) para autenticação na caixa apenas,
- Controle de acesso (WPA3)
- Mensurar tempo de reboot, de patches update

NG Firewall: Implementar um NG Firewall para bloquear acesso de sites específicos, protocolos e portas também. Sendo esta uma primeira barreira

- Proxy para Acesso ao sistema
- API (inspeção de pacotes) -> dinamica a partir do CTI

- VPN + MFA
- SPI (Stateful Packet Inspection): Monitoramento do estado das conexões ativas;
- Hardening de Gerenciamento: Acesso à interface de configuração apenas via VPN + MFA;
- Segurança de Camada 2: Implementação de WPA3 para conexões wireless administrativas.

WAF: Garantir a segurança dos serviços presentes no ambiente, garantindo resistência a ataques sofisticados

- Filtragem de tráfego HTTP/HTTPS
- Bloqueio de ameaças OWASP TOP 10
- Gerenciamento de presença de BOTs;
- Mitigação de DDoS
- Segurança de APIs
- Análise Comportamental com IA;
- Serviços de Identidade: Integração com LDAP/RADIUS para aplicar políticas baseadas no usuário (Identity-Aware).

4. Domínio de Dados e Virtualização (Data Domain)

Estando dentro de Data Domain, nesta camada, o foco reside na proteção dos ativos onde a informação é processada e armazenada.

Virtualização e Contentores (Kubernetes/Docker): Implementar virtualização para serviços específicos, aplicações de uso interno/externo, organização dos ambientes de desenvolvimento e de produção.

- Servidores guest devidamente hardenizados
- Portas abertas estritamente necessárias,
- Serviços rodando apenas sendo os necessários,
- Não permitir root over ssh
- Acesso remoto apenas criptografado e com par de chaves,
- Containers em redes apartadas
- Configuração de redundância nos Pods para balanceamento de carga;
- Sensores de SIEM e XDRs

VMs e Containers (exclusivamente):

- Hardening de Host/Guest: Configuração de SO enxuto (minimal) e desativação de serviços desnecessários;
- Segurança de Acesso: Proibição de login de root via SSH e autenticação exclusiva por par de chaves;
- Isolamento de Rede: Containers operando em redes virtuais apartadas (Micro-segmentação);
- Alta Disponibilidade: Configuração de redundância em Pods e balanceamento de carga nativo;
- Sensores de SIEMs/XDRs

Segurança de Endpoints (Clients): Implementação de modelos *Zero Trust* com MFA obrigatório, criptografia de disco e controle de acesso à rede (NAC 802.1X) para garantir a conformidade dos dispositivos.

- Gestão de Identidade e Acesso (IAM - Zero Trust):
- MFA Obrigatório;

- Criptografia de Disco;
- NAC (Network Access Control - 802.1X) para garantir que apenas dispositivos com certificados digitais válidos e conformidade de segurança (patching em dia, EDR ativo) possam se conectar à rede;
- MDM / UEM (Unified Endpoint Management): Garantir que o sistema operacional esteja atualizado e com as configurações de segurança (GPOs) aplicadas antes de permitir o acesso ao Data Domain;
- Sensores de SIEM e XDR;

Proteção de Dados em Databases e Estações: Aplicação de RBAC (Controle de Acesso Baseado em Funções), criptografia em repouso e auditoria detalhada de consultas às bases de dados.

- RBAC (Role-Based Access Control): Acesso estritamente limitado por função de usuário/aplicação;
- Criptografia em Repouso (At-Rest): Garantir que os dados no disco estejam cifrados
- Auditoria de Consultas (AAA): Logs detalhados de quem acessou qual dado e quando (Audit Trail);
- DLP (Data Loss Prevention) para evitar perda de dados, com bloqueio na transferência de dados e monitoramento de tráfego de dados;
- Sensores de SIEM e XDRs

5. Monitoramento de Servidores e Estações (Data Domain)

Sendo uma continuação de data domain, neste trecho o objetivo é tratar exclusivamente de hosts na rede

Servidores: Servidores on premise conectados à rede, servindo de redundância e também para disponibilizar serviços específicos.

- LDAP e RBAC -> com foco em permitir autenticação dos usuários ao sistema,
- VPN -> para tunelar o tráfego externo;
- Modelo AAA -> para garantir a integridade do ambiente, assim como disponibilizar recursos de auditoria
- Sensores para SIEMs e XDRs

Estações: Inserção de agentes/sensores que permitam monitorar dados, processos e demais elementos do ambiente.

- Gestão de Identidade e Acesso (IAM - Zero Trust):
- MFA Obrigatório;
- Criptografia de Disco;
- NAC (Network Access Control - 802.1X) para garantir que apenas dispositivos com certificados digitais válidos e conformidade de segurança (patching em dia, EDR ativo) possam se conectar à rede;
- MDM / UEM (Unified Endpoint Management): Garantir que o sistema operacional esteja atualizado e com as configurações de segurança (GPOs) aplicadas antes de permitir o acesso ao Data Domain;
- Sensores de SIEM e XDR;

6. Monitorização, Detecção e Resposta (SIEM, EDR & XDR)

A última camada garante a visibilidade transversal e a capacidade de reação a incidentes.

EDR/XDR: Monitorização de processos em tempo real em servidores e estações de trabalho, permitindo o isolamento de hosts infetados e a remediação automática de ameaças como *ransomware*.

- Monitoramento de Processos: Registro de cada execução de binários, scripts e comandos (Powershell, Bash) para detectar anomalias;
- Análise de Árvore de Processos: Identificar se um processo legítimo (como o Word ou um Navegador) gerou um processo suspeito (como um terminal);
- Isolamento de Host: Capacidade de "cortar" a rede do dispositivo infectado remotamente para conter um surto de malware;
- Remediação: Rollback de alterações feitas por ransomware ou remoção automática de persistências no registro/arquivos;
- Visibilidade Transversal: Unificar a visão do que acontece no "Client" com o que o "WAF" e o "CDN" estão vendo;
- Resposta Orquestrada: Se o XDR detecta um ataque no servidor Python (Uvicorn), ele pode automaticamente instruir o Firewall de Borda a bloquear o IP do atacante;
- Threat Hunting: Ferramentas de busca proativa por ameaças baseadas em IOCs (Indicadores de Comprometimento) globais.

SIEM: Centralização e correlação de logs de todas as camadas anteriores (WAF, Firewall, Bases de Dados), facilitando a conformidade normativa e a perícia digital pós-incidente.

- Centralização de Logs (Log Management): Coletar eventos do Roteador, NGFW, WAF, Bancos de Dados e Cloudflare em um único local;
- Correlação de Eventos: Identificar que um erro de login no Banco de Dados (Data Domain) está relacionado a um tráfego suspeito detectado pelo WAF minutos antes;
- Dashboard de Conformidade: Gerar relatórios automáticos para auditorias de conformidade (NIST, ISO 27001);
- Retenção de Dados: Armazenamento histórico de logs para perícia digital (Forensics) após um incidente.

Internet

Rede Privada

Roteador de Borda

Implementar um roteador de borda para filtrar tráfego externo e interno, configurando regras de firewall e NAT.

- Configuração de regras de firewall (iptables/nftables)
- Configuração de NAT (port forwarding)
- Monitoramento de logs de tráfego
- Atualização de firmware e software

NG Firewall

Implementar um NG Firewall para bloquear ataques de intrusão e proteger a rede interna.

- Configuração de regras de firewall (iptables/nftables)
- Configuração de NAT (port forwarding)
- Monitoramento de logs de tráfego
- Atualização de firmware e software

CDN & Edge Protection

Implementar uma CDN e Edge Protection para melhorar a performance e segurança do conteúdo.

- Configuração de regras de firewall (iptables/nftables)
- Configuração de NAT (port forwarding)
- Monitoramento de logs de tráfego
- Atualização de firmware e software

DDoS Mitigation & Scrubbing

Implementar uma solução de mitigação de DDoS para proteger a rede interna de ataques de negação de serviço.

- Configuração de regras de firewall (iptables/nftables)
- Configuração de NAT (port forwarding)
- Monitoramento de logs de tráfego
- Atualização de firmware e software

Rede Externa

NG Firewall

Implementar um NG Firewall para bloquear ataques de intrusão e proteger a rede externa.

- Configuração de regras de firewall (iptables/nftables)
- Configuração de NAT (port forwarding)
- Monitoramento de logs de tráfego
- Atualização de firmware e software

WAF

Implementar um WAF para proteger a aplicação web de ataques de intrusão.

- Configuração de regras de firewall (iptables/nftables)
- Configuração de NAT (port forwarding)
- Monitoramento de logs de tráfego
- Atualização de firmware e software

Rede Externa

VMs e Containers

Implementar VMs e Containers para hospedar as aplicações e serviços.

- Configuração de regras de firewall (iptables/nftables)
- Configuração de NAT (port forwarding)
- Monitoramento de logs de tráfego
- Atualização de firmware e software

Rede Externa

Servidores

Implementar servidores para hospedar as aplicações e serviços.

- Configuração de regras de firewall (iptables/nftables)
- Configuração de NAT (port forwarding)
- Monitoramento de logs de tráfego
- Atualização de firmware e software

Rede Externa

Clientes

Implementar clientes para acessar as aplicações e serviços.

- Configuração de regras de firewall (iptables/nftables)
- Configuração de NAT (port forwarding)
- Monitoramento de logs de tráfego
- Atualização de firmware e software

Rede Externa

Estações

Implementar estações para acessar as aplicações e serviços.

- Configuração de regras de firewall (iptables/nftables)
- Configuração de NAT (port forwarding)
- Monitoramento de logs de tráfego
- Atualização de firmware e software

Rede Externa

Sistema de Monitoramento

Implementar um sistema de monitoramento para acompanhar a saúde da rede e dos serviços.

- Configuração de regras de firewall (iptables/nftables)
- Configuração de NAT (port forwarding)
- Monitoramento de logs de tráfego
- Atualização de firmware e software

Rede Externa

SIEM

Implementar um SIEM para coletar e analisar logs de segurança.

- Configuração de regras de firewall (iptables/nftables)
- Configuração de NAT (port forwarding)
- Monitoramento de logs de tráfego
- Atualização de firmware e software

Rede Externa

EDR/XDR

Implementar um EDR/XDR para detectar e responder a ameaças.

- Configuração de regras de firewall (iptables/nftables)
- Configuração de NAT (port forwarding)
- Monitoramento de logs de tráfego
- Atualização de firmware e software

Rede Externa

Internet

Roteador

Block List

Roteador de Borda

Implementar um roteador de borda para filtrar pacotes maliciosos

- Inspeção de pacotes (SPI)
- criptografia de comunicação (VPN + MFA) para autenticação na cabine apenas;
- controle de acesso (WPA3)
- mensurar tempo de reboot, de patches update

NG Firewall

Implementar um NG Firewall para bloquear acessos dos usuários indesejados no ambiente

Para Proteção de Autenticação

- Para proteção de acesso
- Letícia de ACL
- LDAP/RADIUS (jogar pra autenticação local - Data Domain) -> consome recursos do roteador
- 802.1X
- IPSIDS: Detecção e prevenção de intrusão baseada em assinaturas e anomalias;
- Control application

CDN & Edge Protection

Implementar uma rede de entrega de conteúdo para distribuir carga e mascarar o IP real da infraestrutura.

- Ocultação de Origem: Impedir que o IP do roteador de borda seja exposto publicamente;
- Caching Estratégico: Reduzir a carga nos servidores internos servindo conteúdo estático na borda;
- Anycast Network: Distribuir o tráfego globalmente para mitigar latência e ataques volumétricos.

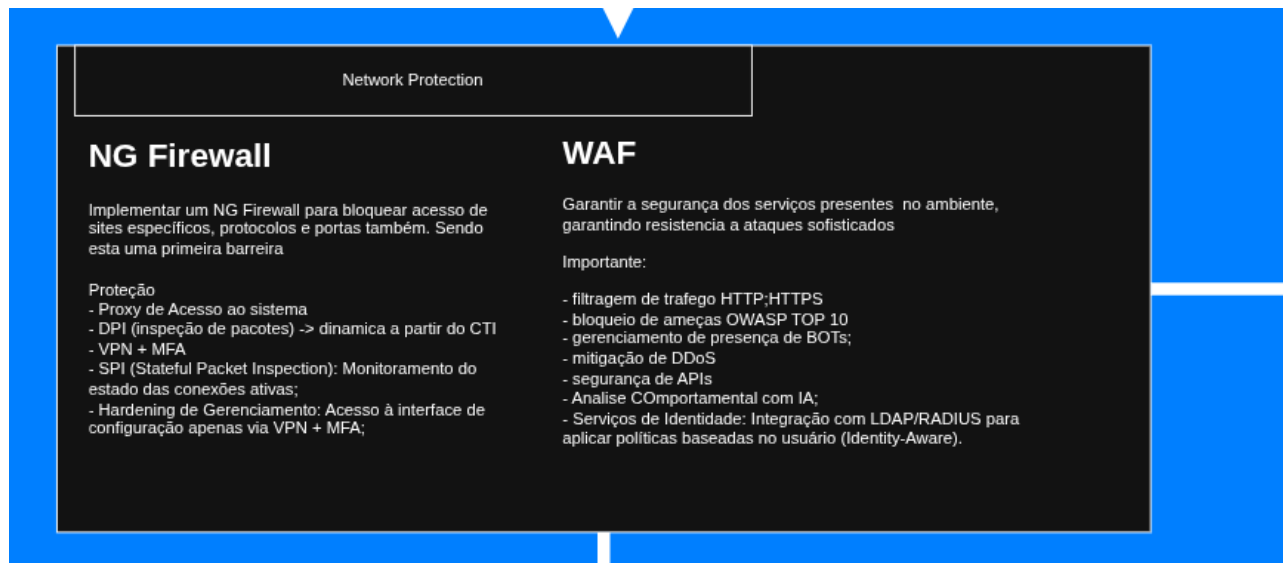
DDOS Mitigation & Scrubbing

Filtragem de tráfego em larga escala para garantir a disponibilidade, Este aqui estaria atrelado ao Firewall.

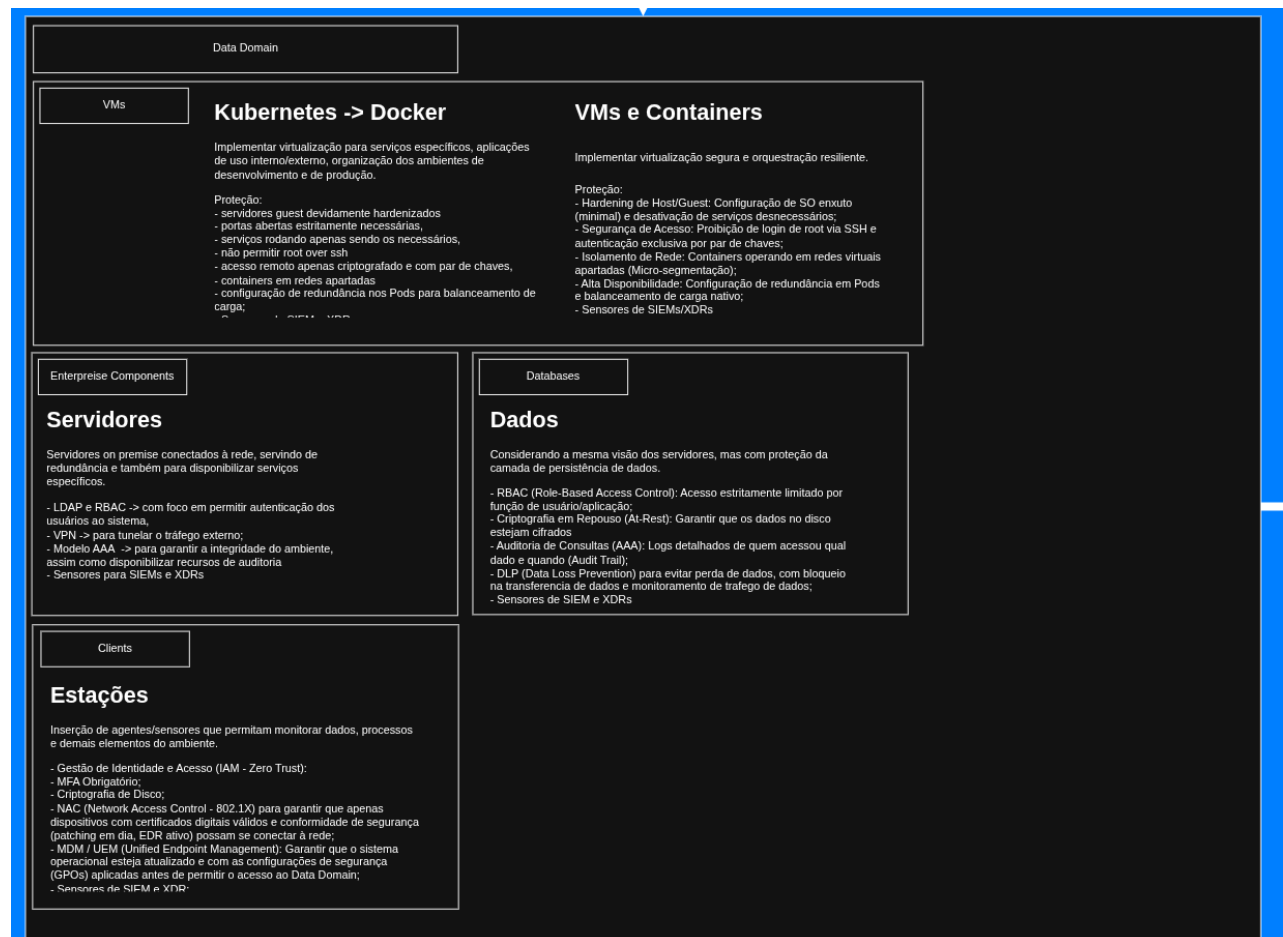
Importante:

- Mitigação de Camada 3, 4 e 7: Bloqueio de ataques de inundação (SYN, UDP flood) e ataques de esgotamento de recursos HTTP;
- Reputação de IP Global: Bloqueio automático de IPs conhecidos por botnets antes de atingirem a rede local.

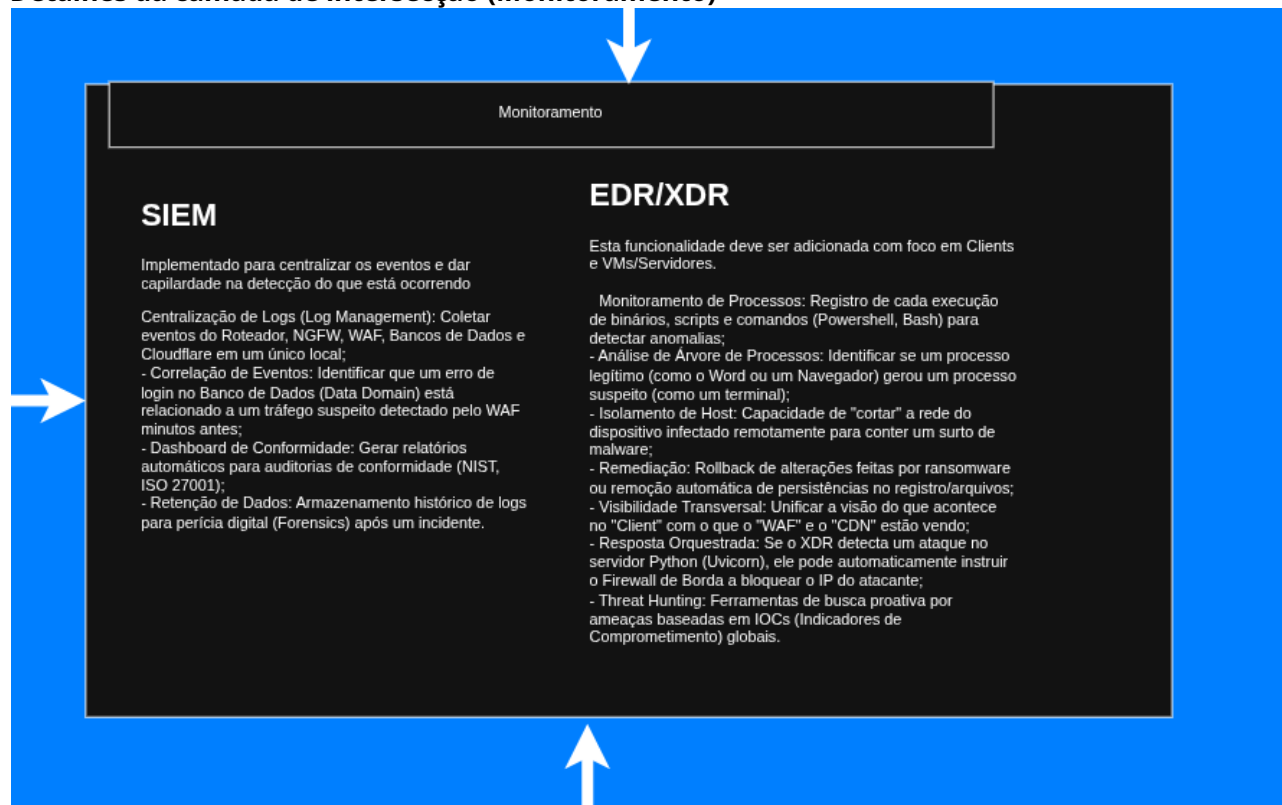
Detalhes da segunda camada



Detalhes da terceira camada



Detalhes da camada de intersecção (Monitoramento)



7. Análise de Vulnerabilidades e Recomendações

7.1 Metodologia de Análise

A análise de vulnerabilidades apresentada foi conduzida por meio de revisão arquitetural do ambiente descrito nos capítulos 1 a 6. Aqui foi feita uma análise na arquitetura proposta e as melhores práticas estabelecidas pelo NIST Cybersecurity Framework (CSF 2.0), pelo CIS Controls v8 e pelas diretrizes ISO/IEC 27001:2022.

7.2 Inventário de Vulnerabilidades Identificadas

O quadro a seguir apresenta o inventário consolidado das vulnerabilidades identificadas, com identificador único, camada/componente afetado, título da vulnerabilidade, classificação CVSS informal, CVE correlata e status recomendado de remediação.

ID	Camada/ Componente	Título	CVSS Informal	CVE Correlata	Status Recomendado
AS-001	Camada 2 / NG Firewall de Borda; Camada 3 / Roteador de Borda e NG Firewall	Exposição de Interface de Gerenciamento SSH na Borda sem Restrição de Origem	Alto	CVE-2023-20198	Remediação Imediata
AS-002	Transversal — Camadas 1 a 6	Ausência de SLA Formal e Ciclo de Vida de Gestão de Vulnerabilidades	Médio	N/A	Processo a Implementar
AS-003	Camada 2 / Reputação de IP Global (blocklist)	Dependência de Blocklist de Reputação de IP como Controle Primário de Acesso	Médio	N/A	Mitigação Técnica
AS-004	Camadas 3, 4 e 5 / LDAP, RADIUS, VPN, Kubernetes	Ausência de Cofre de Segredos e Rotação Automatizada de Credenciais de Serviço	Alto	CVE-2021-25741	Remediação Imediata
AS-005	Camada 6 / SIEM — Retenção Histórica de Logs	Ausência de Retenção Imutável de Logs e Cadeia de Custódia Forense	Alto	N/A	Implementação Prioritária
AS-006	Camada 4 / Kubernetes/Docker — Virtualização	Ausência de Controles de Runtime Kubernetes: Admission Controllers e Pod Security Standards	Crítico	CVE-2022-0185; CVE-2022-24348	Remediação Imediata
AS-007	Camadas 4 e 5 / IAM Zero Trust, LDAP, RBAC, MDM/UEM	Ausência de Processo JML no Ciclo de Vida de Identidades	Alto	N/A	Processo a Implementar
AS-008	Camadas 2, 3 e 5 / LDAP/RADIUS (Identity-Aware)	Ponto Único de Falha em LDAP/RADIUS — Ausência de Alta Disponibilidade	Crítico	N/A	Remediação Imediata
AS-009	Camadas 2 a 5 — interfaces inter-camadas	Ausência de Segmentação Formal de Rede entre Camadas — Risco de Movimento Lateral Inter-Camadas	Alto	N/A	Implementação Prioritária
AS-010	Camada 4 / Proteção de Bancos de Dados — DLP	DLP sem Classificação Formal de Dados — Controle sem Taxonomia de Criticidade	Médio	N/A	Processo a Implementar

7.3 Análise por Vulnerabilidade

AS-001 — Exposição de Interface de Gerenciamento SSH na Borda sem Restrição de Origem

Camada/Componente afetado: Camada 2 (NG Firewall de Borda) e Camada 3 (Roteador de Borda e NG Firewall — segunda instância).

- **Risco:** Um adversário com alcance à infraestrutura de rede pública pode executar ataques de força bruta, explorar vulnerabilidades em daemons SSH desatualizados ou reutilizar credenciais comprometidas para obter acesso administrativo a dispositivos de borda. O comprometimento de um firewall de borda representa acesso à topologia de rede interna, à tabela de rotas e à possibilidade de desabilitar ou reconfigurar controles de segurança das camadas subsequentes. Classificação CVSS informal: Alto (8,1).
- **CVE Correlata:** CVE-2023-20198 — vulnerabilidade de autenticação remota indevida em interface de gerenciamento de dispositivo Cisco IOS XE exposta à rede; citada como referência genérica ao padrão de risco de interfaces de gerenciamento expostas.

- **Mitigação Recomendada:** Implementação de rede de gerenciamento dedicada e isolada (OOB Management Network), com ACLs que permitam sessões SSH exclusivamente a partir de endereços IP pertencentes à rede de gerenciamento. Desabilitação do SSH na interface WAN de todos os dispositivos de borda (Camadas 2 e 3). Adoção de autenticação por par de chaves criptográficas (RSA mínimo 4096 bits ou Ed25519), com eliminação de autenticação por senha para sessões SSH administrativas. Implementação de registro e alertas, via SIEM (Camada 6), de tentativas de conexão SSH à interface de borda.

AS-002 — Ausência de SLA Formal e Ciclo de Vida de Gestão de Vulnerabilidades

Camada/Componente afetado: Transversal a todas as camadas (1 a 6) — afeta NG Firewalls, Roteador de Borda, WAF, Kubernetes/Docker, servidores on-premise, endpoints e o ecossistema SIEM/EDR/XDR.

- **Risco:** Sem SLA de remediação formalmente estabelecido, vulnerabilidades técnicas conhecidas podem permanecer exploráveis por período indeterminado em qualquer componente da arquitetura. A probabilidade de exploração de uma vulnerabilidade aumenta proporcionalmente ao seu tempo de exposição, conforme demonstrado pelo Exploit Prediction Scoring System (EPSS). Classificação CVSS informal: Médio (6,5).
- **CVE Correlata:** N/A — trata-se de lacuna de processo de governança, não de vulnerabilidade em produto específico.
- **Mitigação Recomendada:** Formalização de uma Política de Gestão de Vulnerabilidades alinhada ao NIST SP 800-40 Rev. 4, estabelecendo SLAs de remediação por faixa de criticidade CVSS, periodicidade de varreduras autenticadas cobrindo todas as camadas descritas, processo de change management integrado ao ciclo de patching, e revisão periódica do inventário de ativos com seus respectivos níveis de firmware e software. A política deve ser aprovada formalmente pela liderança e revisada anualmente.

AS-003 — Dependência de Blocklist de Reputação de IP como Controle Primário de Acesso

Camada/Componente afetado: Camada 2 — componente Reputação de IP Global (blocklist de botnets).

- **Risco:** Adversários que utilizam IPs de reputação neutra ou que operam por meio de hosts legítimos comprometidos podem contornar integralmente esse controle, avançando para as camadas subsequentes sem restrição. Classificação CVSS informal: Médio (5,3).
- **CVE Correlata:** N/A — trata-se de limitação arquitetural de controle, não de vulnerabilidade em produto específico.
- **Mitigação Recomendada:** Integração de feeds de Cyber Threat Intelligence (CTI) em tempo real ao componente de IPS/IDS e ao NG Firewall de borda (ambos já descritos na Camada 2), implementando atualização dinâmica de regras de bloqueio com latência inferior a 1 hora. Complementação do controle de reputação de IP com análise comportamental de tráfego no WAF (Camada 3), incluindo JA3/JA3S fingerprinting para identificação de clientes TLS maliciosos e análise de padrões de requisição HTTP/HTTPS.

AS-004 — Ausência de Cofre de Segredos e Rotação Automatizada de Credenciais de Serviço

Camada/Componente afetado: Camadas 3, 4 e 5 — componentes LDAP/RADIUS (Serviços de Identidade na Camada 3), credenciais de serviço em Kubernetes/Docker e senhas de bind de bancos de dados (Camada 4), e LDAP + RBAC em servidores on-premise (Camada 5).

- **Risco:** O comprometimento de um único arquivo de configuração, imagem de container ou variável de ambiente em qualquer componente das Camadas 3, 4 ou 5 pode expor credenciais com acesso privilegiado a múltiplos sistemas, viabilizando movimento lateral horizontal e escalação de privilégios para alcançar ativos críticos (bancos de dados, servidores on-premise,

infraestrutura VPN). Classificação CVSS informal: Alto (8,5).

- **CVE Correlata:** CVE-2021-25741 — exposição de credenciais de serviço via volumes hostPath em Kubernetes, permitindo acesso a segredos do nó hospedeiro; citada como referência genérica ao padrão de armazenamento inseguro de credenciais em ambientes containerizados.
- **Mitigação Recomendada:** Implementação de cofre de segredos centralizado integrado ao orquestrador Kubernetes (Camada 4) e aos servidores on-premise (Camada 5), com política de rotação automatizada de credenciais em intervalos definidos por criticidade (recomendado: credenciais privilegiadas a cada 30 dias, demais credenciais a cada 90 dias). Proibição formal de credenciais em texto claro em arquivos de configuração, imagens de container ou variáveis de ambiente sem cifragem. Integração dos eventos de acesso ao cofre de segredos ao SIEM (Camada 6) para auditoria contínua.

AS-005 — Ausência de Retenção Imutável de Logs e Cadeia de Custódia Forense

Camada/Componente afetado: Camada 6 — componente SIEM, especificamente a função de retenção histórica de logs (forense) e centralização de logs.

- **Risco:** Em cenário de incidente de segurança grave, logs adulterados ou destruídos por um adversário com acesso ao SIEM inviabilizam a reconstrução da linha do tempo do ataque, comprometem processos de responsabilização e podem resultar em violações de obrigações legais regulatórias — incluindo a LGPD (Lei n.º 13.709/2018) e a ISO/IEC 27037:2012. Classificação CVSS informal: Alto (7,5).
- **CVE Correlata:** N/A — trata-se de lacuna arquitetural de processo, não de vulnerabilidade em produto específico.
- **Mitigação Recomendada:** Implementação de armazenamento imutável (WORM) para o repositório de logs do SIEM, com retenção mínima de 12 meses em armazenamento quente e 24 meses em arquivo frio. Implementação de integridade criptográfica via hash SHA-256 encadeado por lote de eventos, com verificação periódica de integridade automatizada. Segregação de credenciais de acesso de escrita ao repositório de logs, restringindo-as a contas de serviço com auditoria de uso integrada ao próprio SIEM. Formalização de procedimento documentado de cadeia de custódia para exportação de logs em contextos de investigação forense, em conformidade com a ISO/IEC 27037:2012.

AS-006 — Ausência de Controles de Runtime Kubernetes: Admission Controllers e Pod Security Standards

Camada/Componente afetado: Camada 4 — componente Virtualização (Kubernetes/Docker), especificamente os servidores guest hardenizados, containers em redes apartadas e mecanismos de redundância nos Pods.

- **Risco:** Um adversário com acesso ao API Server do Kubernetes pode iniciar containers privilegiados, montar sistemas de arquivos do host ou acessar segredos de outros namespaces, comprometendo o nó e potencialmente o cluster inteiro. Classificação CVSS informal: Crítico (9,0) — impacto total em confidencialidade, integridade e disponibilidade.
- **CVE Correlata:** CVE-2022-0185 — escalação de privilégios via overflow em syscall de namespace do kernel Linux, explorável a partir de containers sem restrição de capabilities; CVE-2022-24348 — path traversal no Argo CD que permite acesso a segredos de outros namespaces Kubernetes.
- **Mitigação Recomendada:** Habilitação do Pod Security Admission (PSA) em modo restricted para todos os namespaces de workloads de produção no cluster Kubernetes. Implementação de Admission Controller baseado em política (OPA/Gatekeeper ou Kyverno) com regras que proíbam explicitamente: containers privilegiados (privileged: true), montagem de volumes

hostPath, execução como usuário root, uso de capabilities Linux além do conjunto mínimo necessário. Implementação de NetworkPolicy Kubernetes para formalizar e complementar a micro-segmentação de rede declarada na Camada 4. Integração de varredura de imagens de container ao pipeline de implantação e em tempo de runtime, com alertas integrados ao SIEM (Camada 6).

AS-007 — Ausência de Processo JML no Ciclo de Vida de Identidades

Camada/Componente afetado: Camadas 4 e 5 — componentes IAM Zero Trust (Gestão de Identidade), LDAP + RBAC (autenticação em servidores on-premise), MDM/UEM com GPOs (estações de trabalho) e auditoria AAA em bancos de dados.

- **Risco:** Contas de ex-colaboradores ou colaboradores com perfis de acesso desatualizados representam vetores de ataque privilegiados, especialmente em cenários de ameaça interna (insider threat) ou comprometimento de credenciais. Contas com permissões acumuladas ao longo de mudanças de função violam o princípio do menor privilégio (Principle of Least Privilege), fundamento do modelo Zero Trust descrito na arquitetura. Classificação CVSS informal: Alto (7,8).
- **CVE Correlata:** N/A — trata-se de lacuna de processo de governança de identidades, não de vulnerabilidade em produto específico.
- **Mitigação Recomendada:** Formalização e implementação do processo JML integrado ao LDAP/RADIUS e ao IAM Zero Trust descritos nas Camadas 4 e 5, compreendendo: (a) provisionamento automatizado de acessos vinculado ao sistema de recursos humanos na admissão; (b) revisão e ajuste de perfis de acesso em até 48 horas em mudanças de função; (c) revogação imediata e desativação de conta em prazo máximo de 24 horas após registro de desligamento; (d) revisão periódica de acessos com frequência mínima semestral para todas as contas, e trimestral para contas privilegiadas. Integração dos eventos de provisionamento e revogação de acessos ao SIEM (Camada 6).

AS-008 — Ponto Único de Falha em LDAP/RADIUS — Ausência de Alta Disponibilidade

Camada/Componente afetado: Camadas 2, 3 e 5 — componente LDAP/RADIUS (Identity-Aware) na Camada 2 (NG Firewall de borda e 802.1X), na Camada 3 (Serviços de Identidade, VPN e NG Firewall) e na Camada 5 (LDAP + RBAC em servidores on-premise).

- **Risco:** A indisponibilidade do serviço LDAP/RADIUS impede o acesso legítimo de administradores e usuários a todos os sistemas que dependem dessa autenticação, podendo resultar em negação de serviço operacional ampla — inclusive bloqueando a capacidade de resposta a incidentes em curso, caso os analistas do SOC não consigam autenticar-se nas ferramentas da Camada 6. Adicionalmente, configurações de fallback sem HA (política fail-open) podem criar janelas de acesso não autenticado durante indisponibilidade. Classificação CVSS informal: Crítico (9,1).
- **CVE Correlata:** N/A — trata-se de lacuna arquitetural de resiliência e disponibilidade, não de vulnerabilidade em produto específico.
- **Mitigação Recomendada:** Implementação de arquitetura de Alta Disponibilidade para o serviço LDAP, com replicação multi-master ou configuração primary/secondary com failover automático e monitoramento de saúde. Para o serviço RADIUS, implementar redundância com pelo menos dois servidores ativos e configurar os clientes RADIUS — NG Firewall, Roteador de Borda e NAC (Camadas 2, 3 e 5) — com parâmetros de failover para o servidor secundário. Definição e teste periódico semestral de RTO e RPO para o serviço de identidade. Integração do monitoramento de saúde do LDAP/RADIUS ao SIEM (Camada 6) com alertas automáticos de indisponibilidade.

AS-009 — Ausência de Segmentação Formal de Rede entre Camadas — Risco de Movimento Lateral Inter-Camadas

Camada/Componente afetado: Camadas 2 a 5 — interfaces entre Camada 2 (Edge Security) e Camada 3 (Block List & Network Protection), entre Camada 3 e Camada 4 (Data Domain) e entre Camada 4 e Camada 5 (servidores on-premise e estações de trabalho).

- **Risco:** Um adversário que comprometa um componente da Camada 2 pode ter visibilidade de rede ou rotas diretas para componentes das Camadas 3 a 5, viabilizando movimento lateral progressivo até atingir os ativos de maior valor — bancos de dados da Camada 4 e servidores on-premise da Camada 5. Esse vetor é consistente com o padrão tático TA0008 (Lateral Movement) do framework MITRE ATT&CK. Classificação CVSS informal: Alto (8,2).
- **CVE Correlata:** N/A — trata-se de lacuna de design arquitetural de rede, não de vulnerabilidade em produto específico.
- **Mitigação Recomendada:** Definição e documentação formal de zonas de rede (zona de borda/DMZ externa, zona de filtragem, zona de aplicação, zona de dados, zona de gerenciamento) com controles de filtragem stateful explícitos nas interfaces entre cada zona. Adoção de política de negação por padrão (default-deny) com permissões de tráfego explicitamente definidas por protocolo, porta e direção. Elaboração de diagrama de fluxo de dados (DFD) entre camadas como artefato formal de arquitetura de segurança. Realização de testes de penetração inter-camadas para validar empiricamente a eficácia da segmentação implementada, com registro dos resultados no SIEM (Camada 6).

AS-010 — DLP sem Classificação Formal de Dados — Controle sem Taxonomia de Criticidade

Camada/Componente afetado: Camada 4 — componente Proteção de Bancos de Dados, especificamente o mecanismo de DLP (Data Loss Prevention) com bloqueio de transferência e monitoramento.

- **Risco:** Sem taxonomia formal, o DLP converte-se em um controle de conformidade declaratório sem eficácia mensurável, expondo a organização a riscos de exfiltração de dados sensíveis e potenciais violações regulatórias da LGPD (Lei n.º 13.709/2018), especialmente no que concerne ao tratamento de dados pessoais e dados pessoais sensíveis armazenados nos bancos de dados da Camada 4. Classificação CVSS informal: Médio (6,0).
- **CVE Correlata:** N/A — trata-se de lacuna de processo de governança de dados, não de vulnerabilidade em produto específico.
- **Mitigação Recomendada:** Elaboração e aprovação formal de uma Política de Classificação de Dados, estabelecendo níveis de sensibilidade com critérios objetivos de classificação e mapeamento das categorias de dados aos ativos de bancos de dados da Camada 4. Integração da taxonomia aprovada às regras de DLP, aos perfis de RBAC e às políticas de auditoria AAA já descritos na arquitetura. Extensão da criptografia para dados em trânsito, com exigência de TLS 1.2 ou superior em todas as conexões entre aplicações e bancos de dados. Implementação de mascaramento e tokenização de dados sensíveis em ambientes de desenvolvimento, testes e homologação. Revisão anual da política de classificação de dados.

7.4 Priorização e Plano de Ação

A priorização das vulnerabilidades identificadas fundamentou-se em dois critérios combinados: (1) classificação CVSS informal, com ênfase nas vulnerabilidades classificadas como Crítico e Alto, que representam risco imediato de comprometimento sistêmico; e (2) impacto sobre a resiliência operacional, priorizando vulnerabilidades que afetam a disponibilidade de serviços transversais (LDAP/RADIUS — AS-008), que viabilizam comprometimento sistêmico do orquestrador de workloads (AS-006), ou que expõem interfaces administrativas à rede pública (AS-001). O plano de ação em três fases distribui as vulnerabilidades conforme urgência e complexidade de remediação, alinhando-se

ao ciclo PDCA (Plan-Do-Check-Act) preconizado pela ISO/IEC 27001:2022 e ao processo de gerenciamento de riscos do NIST CSF 2.0.

Fase 1 — Contenção Imediata (0–30 dias): AS-001, AS-004, AS-006, AS-008. As vulnerabilidades alocadas na Fase 1 apresentam classificação Crítico ou Alto com alta probabilidade de exploração e impacto imediato sobre a integridade ou a continuidade operacional do ambiente. AS-001 exige restrição imediata de acesso SSH às interfaces WAN dos dispositivos de borda (Camadas 2 e 3) e auditoria de ACLs existentes. AS-004 exige auditoria emergencial de arquivos de configuração e variáveis de ambiente em containers Kubernetes e servidores on-premise, com remoção imediata de credenciais em texto claro identificadas. AS-006 exige a habilitação imediata do Pod Security Admission em modo restricted nos namespaces de produção do orquestrador Kubernetes (Camada 4). AS-008 exige o início imediato do deployment do segundo servidor LDAP/RADIUS em configuração de failover nas Camadas 2, 3 e 5.

Fase 2 — Fortalecimento Técnico (31–60 dias): AS-003, AS-005, AS-007, AS-009. As vulnerabilidades da Fase 2 requerem implementações técnicas de maior escopo arquitetural. AS-003 exige a integração de feeds de CTI em tempo real ao IPS/IDS e ao NG Firewall de borda (Camada 2) e a configuração de análise comportamental no WAF (Camada 3). AS-005 exige a implementação de armazenamento imutável (WORM) e mecanismos de integridade criptográfica para o repositório de logs do SIEM (Camada 6). AS-007 exige o mapeamento de todas as contas ativas, identificação de contas órfãs, e formalização do processo JML integrado ao LDAP e ao IAM Zero Trust das Camadas 4 e 5. AS-009 exige a revisão e documentação formal do diagrama de zonas de rede e a implementação de regras de filtragem inter-camadas com política de negação por padrão.

Fase 3 — Resiliência e Maturidade (61–90 dias): AS-002, AS-010. As vulnerabilidades da Fase 3 correspondem a lacunas de governança e processo que requerem engajamento organizacional amplo e aprovação formal pela liderança. AS-002 exige a elaboração, aprovação e operacionalização de uma Política de Gestão de Vulnerabilidades com SLAs por criticidade, integrada ao processo de change management e abrangendo todas as camadas descritas na arquitetura. AS-010 exige a elaboração e aprovação formal de uma Política de Classificação de Dados com taxonomia de criticidade mapeada aos ativos de bancos de dados da Camada 4, seguida da reconfiguração das regras de DLP conforme a taxonomia estabelecida.

8. Conclusão

A arquitetura proposta oferece uma visão holística da segurança da informação, alinhando controles técnicos rigorosos com as melhores práticas internacionais. A integração entre as barreiras de proteção e os sensores de monitorização permite uma resposta coordenada, reduzindo significativamente a superfície de ataque da organização.